Staff Information Security Handbook

Version 4 · Applies to all staff, students, contractors and visitors with an Institute account

Synthetic sample: this handbook belongs to a fictional institute and was written for software testing.

About this handbook

This handbook explains what every member of staff must do to keep the Institute’s information and systems safe. It turns the information security policy approved by the Board of Governors into practical rules for daily work. Where this handbook and the policy differ, the policy applies, and the difference should be reported to the information security team so that the handbook can be corrected.

The handbook is written for people who are not security specialists. It does not try to cover every situation. If you are unsure whether something is allowed, ask before you act: a short question to the service desk is always better than a long investigation afterwards.

The handbook is reviewed every year by the information security team, and earlier if the law, the policy or the threats we face change significantly. The version number and the date of the last review are shown on the last page.

Who must follow it

The handbook applies to all employees, whether permanent, fixed-term or part-time, and to students, visiting researchers, contractors, agency staff and volunteers who are given an Institute account. In this handbook they are all called “staff”.

It applies wherever you work and whatever device you use, as long as you are handling Institute information or using Institute systems. That includes working from home, at a partner’s site, while travelling and on your own devices.

Managers are responsible for making sure that the people who report to them have read the handbook and completed the annual security training. People who host visitors or contractors are responsible for telling them which rules apply to them.

Your responsibilities

You are responsible for the information you create, receive and handle, and for the accounts and devices you are given. In particular, you must:

- complete the security awareness training when you join and every year after that;
- use Institute information only for the purpose for which you were given access;
- keep your accounts to yourself and never let anyone else work under your name;
- lock your screen whenever you leave your device, even for a moment;
- follow the rules in this handbook and any additional rules for the systems you use.

Some roles carry extra responsibilities. System owners decide who may access their systems and review those permissions at least twice a year. Line managers tell the service desk on the day a member of their team leaves or changes role, so that access can be removed or adjusted.

Passwords and signing in

Your password protects everything you can access. Choose a passphrase of at least 12 characters that you do not use anywhere else, for example three or four unrelated words. You do not have to change it on a schedule, but you must change it straight away if you think someone else may know it.

Multi-factor authentication is required for email, remote access and every system that holds confidential information. Approve a sign-in request on your phone only when you have just tried to sign in yourself. If you receive a request you did not expect, reject it and report it.

Use the password manager provided by the Institute to store passwords for systems that do not use single sign-on. Do not write passwords on paper, store them in documents or send them by email. The service desk will never ask you for your password, by phone or in any other way.

Removable media

USB sticks, external hard drives and memory cards are easily lost and are a common way for malicious software to spread. Use them only when there is no practical alternative, such as the Institute’s file storage or the approved sharing services.

If you must use removable media, use only encrypted devices issued by the service desk. Personal USB sticks must not be connected to Institute computers, and devices found in public places or received unexpectedly must be handed to the service desk unopened.

Confidential information may be copied to removable media only with the agreement of the information owner. Delete the files from the device as soon as they have reached their destination, and return the device to the service desk when you no longer need it.

Email and phishing

Most attacks on the Institute start with an email. Be suspicious of messages that create urgency, ask you to sign in, open an attachment or change bank details, even if they appear to come from a colleague. Check the sender’s address carefully and hover over links before you click them.

If you think a message is a phishing attempt, use the “Report message” button in your mail client. This sends a copy to the security team and removes it from your inbox. Do not forward suspicious messages to colleagues to ask their opinion. You may still use the unsubscribe link in newsletters that you signed up for yourself.

Do not automatically forward Institute email to a personal account. When you send confidential information by email, check the recipients before you press send and use the encryption option for anyone outside the Institute.

Working away from the office

You may work from home and other locations if your role allows it. Make sure that people around you cannot read your screen or overhear confidential calls, and do not leave devices unattended in cars, trains or cafes.

Connect to Institute systems through the virtual private network or the web portals provided. Public Wi-Fi may be used only through the virtual private network. Do not use shared or public computers,

such as those in hotels or libraries, to access Institute systems.

When you travel abroad, take only the information you need. Some countries restrict the use of encryption or may inspect devices at the border; the security team can provide a clean travel laptop for trips to higher-risk destinations, which must be requested at least ten working days in advance.

Mobile devices

Institute email and files may be used on a mobile phone or tablet only if the device is enrolled in the Institute’s device management service. Enrolment sets a screen lock, encrypts the device and allows Institute data to be wiped remotely if the device is lost.

Keep the operating system and apps up to date and install apps only from the official app stores. Do not remove the security restrictions that the manufacturer has built into the device.

If you lose a device that holds Institute information, report it to the service desk immediately, day or night. On a personal device, a remote wipe removes only Institute data and leaves your own photos and files untouched.

Video calls and meetings

Use the Institute’s video conferencing service for meetings in which confidential matters are discussed. Other services may be used for public events and for meetings that a partner organises, but do not share confidential documents through their chat or file functions.

Before you share your screen, close documents and messages that the other participants should not see, and turn off notifications. When you record a meeting, tell the participants at the start, store the recording in the Institute’s file storage and delete it when it is no longer needed.

Meeting links for confidential meetings should require participants to wait in the lobby until the host admits them. Do not post such links in public channels or calendars.

Printing and paper records

Print confidential information only when you need a paper copy. Use the secure print release on the shared printers, so that documents are printed only when you are standing at the printer. Collect your printouts straight away.

Keep confidential papers in a locked drawer or cabinet when you are not using them, and clear your desk at the end of the day. Do not take confidential papers home unless your manager has agreed and you can store them securely there.

Dispose of paper that contains personal or confidential information in the locked confidential waste bins. Ordinary recycling bins must not be used for such paper, even if it has been torn up.

Visitors and building access

Wear your Institute identity card where it can be seen while you are on site. Do not lend your card to anyone, and do not hold secure doors open for people you do not recognise; politely direct them to reception instead.

Visitors must sign in at reception, wear a visitor badge and be accompanied by their host while they are in areas that are not open to the public. The host is responsible for the visitor until they have

signed out.

Server rooms, laboratories with restricted equipment and the records store have additional access controls. Access to them is granted by the area manager and is reviewed every six months.

Software and updates

Install software only from the Institute’s software centre or with the approval of the service desk. Free tools and browser extensions can collect data or contain malicious code, and many are not licensed for use by organisations.

Updates for operating systems and common applications are installed automatically. Restart your computer when you are asked to, and at least once a week, so that the updates take effect. Computers that have not been updated for 30 days are blocked from the network until they are brought up to date.

If you develop or run your own software for research, follow the secure development guidance published by the research computing team, and register any service that is reachable from the internet.

Artificial intelligence tools

Generative artificial intelligence tools can help with drafting, translation and coding, but anything you type into a public tool may be stored and used by its provider. Use only the tools listed as approved on the staff portal, and sign in with your Institute account so that the Institute’s contract terms apply.

Do not enter confidential information, personal data or unpublished research results into a tool that is not approved for that level of information. Check the output before you use it: tools can produce plausible text that is wrong, and you remain responsible for the result.

If you want to use a new tool, or to connect a tool to Institute systems or data, ask the information security team for a review first. The review usually takes two to three weeks.

Classifying information

All Institute information is classified into one of three levels. Public information may be shared with anyone. Internal information is for staff and authorised partners. Confidential information could cause harm to people or to the Institute if it were disclosed, and includes personal data, unpublished research results, contracts and security information.

The person who creates or receives information is responsible for classifying it. Mark confidential documents with the label “Confidential” in the header, and choose the matching sensitivity label in the office applications, which applies the right protection automatically.

If you are unsure which level applies, treat the information as confidential until the information owner has decided. Reclassify information when its sensitivity changes, for example when research results are published.

Sharing files with partners

When you share files with people outside the Institute, use the approved file transfer service or the collaboration sites set up by the service desk. Links must be limited to named people and should expire when the project ends.

Before you share confidential information, check that there is a contract or data sharing agreement that allows it, and share only the minimum that the partner needs. The research contracts office can tell you whether an agreement is in place.

Do not use personal cloud storage, messaging apps or file sharing websites for Institute information, even for a single transfer.

Research data

Research data is often the Institute’s most valuable information, and some of it is subject to conditions set by funders, ethics committees or the people who provided it. Every project that handles personal or confidential data must have a data management plan that says where the data is stored and who may access it.

Store research data in the research storage service or a project space set up by research computing, which is backed up and access-controlled. Laptops and desktop computers may hold working copies only, and only if their disks are encrypted.

When a project ends, archive the data that must be kept in the research data repository and delete the rest, following the data management plan. Tell research computing when a project space can be closed.

Payment card and bank details

Card payments must be taken only through the Institute’s payment pages and card terminals. Never write down card numbers, store them in spreadsheets or send them by email, and never ask a customer to send card details in a message.

Requests to change a supplier’s or an employee’s bank details are a common form of fraud. Before you act on such a request, confirm it by phoning the supplier or colleague on a number you already hold, not on a number given in the request.

Report any suspected payment fraud to the finance team and the service desk at once. The sooner the bank is told, the greater the chance of recovering the money.

Social media and public statements

You may mention your work at the Institute on social media, but do not publish confidential information, photographs of restricted areas or details of security arrangements. Be careful with photographs taken in offices and laboratories, where screens, whiteboards and documents may be visible in the background.

Only the communications office may speak on behalf of the Institute. If a journalist contacts you about a security incident, refer them to the communications office and do not comment yourself.

Attackers use public profiles to prepare targeted phishing messages. Consider limiting the personal details you publish, such as your date of birth, and be wary of unexpected connection requests from

people who claim to work in the same field.

Keeping and deleting records

Keep information only for as long as it is needed. The records retention schedule says how long each type of record must be kept, from a few months for routine correspondence to many years for research data and financial records.

Store records in the Institute’s file storage or the business system intended for them, not on the local drive of your computer, so that they are backed up and can be found by colleagues when you are away.

When records reach the end of their retention period, delete them or arrange for them to be destroyed securely. Do not delete records that are subject to a request for information or a legal hold, even if their retention period has ended.

Reporting a security incident

A security incident is anything that puts the confidentiality, integrity or availability of Institute information at risk: for example a lost laptop, an email sent to the wrong person, a successful phishing attack, a suspicious sign-in or a door to a secure area left open.

Report every incident, or anything you think might be one, to the service desk within 24 hours of noticing it. Use the incident form on the staff portal or call the service desk; outside working hours the phone line is answered by the on-call security officer.

Do not try to investigate the incident yourself, delete evidence or contact the people involved, unless the security team asks you to. Reporting quickly matters more than knowing every detail, and you will not be blamed for reporting something that turns out to be harmless.

Some incidents involving personal data must be reported to the data protection authority within 72 hours. The security team decides whether that is necessary, which is why early reports from staff are so important.

Breaches of this handbook

Breaking the rules in this handbook may put people and the Institute at risk. Deliberate or repeated breaches may lead to disciplinary action, and serious cases may be reported to the police or to regulators.

Honest mistakes are treated differently. If you make a mistake, report it straight away; the aim is to limit the harm and to learn from what happened, not to punish the person who reported it.

Contacts and further guidance

Service desk: through the staff portal or on extension 4400, staffed from 8:00 to 18:00 on working days, with an on-call officer outside those hours for incidents.

Information security team: for questions about this handbook, risk assessments and security reviews of new systems.

Data protection officer: for questions about personal data, data sharing agreements and the rights of the people whose data we hold.

The full information security policy, the records retention schedule and the secure development guidance are published on the staff portal.

Last reviewed by the information security team in September 2026. Next review due September 2027.